SBOM / CVE / Patch

Çıktı: Vulne

Ad Soyad	Grup	Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, etkiliyor: 1) Bileşen var (kütüphane PLC'de mevcut), 2) Sürüm etkileniyor (v2.4 zafiyetli sürümle eşleşiyor), 3) Açık ulaşılabilir (CVSS 9.8, ağ üzerinden uzaktan erişilebilir).

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, durdurulmaz. OT'de süreklilik esastır; plansız ani duruş tutkalın donmasına, kutu sıkışmasına ve üretim kaybına neden olur. Tehdit önce ağ izolasyonuyla sınırlandırılır, yama ilk planlı duruşta atılır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test edilir. Canlı hatta doğrudan uygulanmaz; varsa yedek PLC test tezgâhında (bench) veya yazılım simülasyonunda test edilir. Canlıda yapılacaksa yalnızca planlı bakımda tam yedek (golden backup) alınarak denenir.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir. Yama sürüm notlarından (release notes) emniyet fonksiyonu değişikliği kontrol edilir ve Safety PLC'nin güvenlik imza kodu (Safety Checksum / F-CRC) karşılaştırılarak anlaşılır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   PLC ağ seviyesinde izole edilir (VLAN / endüstriyel firewall), kullanılmayan portlar ve uzaktan erişimler (VPN) kapatılır, PLC panosu kilitlenerek fiziksel/USB erişimi kısıtlanır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.